Post-Quantum Cryptography Transition from an Organisation Information/Cyber Security Perspective

Part 2 Report from Perspective 3: Information security and organizational cybersecurity
Course: Oulu Software DEV-Maintenance-Ops
Group: Group 23
Members: Kaiquan Mah | Quoc Nguyen | Danish Sharjeel | Manh Nguyen | Kim Nguyen
Note: This report is written from the perspective of someone not from a Computer Science background. Technical details from `part1_documentation.md` are summarised using simpler language where possible
Repository is accessible from: https://github.com/kai-oulu/oulu-sdmo-group23/tree/main

---

1. Summary: Quantum is a Business Risk Today

Quantum computers will break RSA and elliptic-curve cryptography that protects internet traffic today. The threat is not something in the future when quantum computing is usable everywhere. Instead the threat is happening now based on a "harvest now, decrypt later" concept, where attackers can gather encrypted data now (like taking our locked safe) and open it later when quantum computers can pick our old locks [5].

NIST published a quantum standard FIPS 203 ML-KEM (Module-Lattice-based Key Encapsulation Mechanism) in August 2024 [1]. ML-KEM is described as a quantum-safe lock that even quantum computers cannot pick. It comes in 3 strengths: ML-KEM-512 (~AES-128 security, Category 1), 768 (~AES-192, Category 3), 1024 (~AES-256, Category 5) [1][2].

For organizations with thousands of low-cost sensors, they cannot replace all their sensor devices overnight. EU and CISA both recommend a hybrid deployment: keep legacy sensor devices running while adding PQC (Post-Quantum Cryptography) on internet-facing links, with fallbacks to ensure compatibility with legacy sensor devices [3][5]. **Migration will take 10-20 years for organizations that use alot of sensor devices** [3].

If your data needs 5+ years of confidentiality (medical records, IP, financial, government secrets), migration is already overdue. EU notes that with CRQC (cryptographically relevant quantum computer) predicted to become available and widely used by 2030, if `cover time` is 5 years or more (refer to the section below to understand more about 'cover time'), it is already too late for many organizations to move in time [3]. For such data, "harvest now, decrypt later" means traffic captured today can be decrypted retroactively once quantum arrives [2].

What is Cover Time?

Cover time = How long you need your data to stay secret. Think of it as an expiry date for confidentiality.

Data Type	Typical Cover Time Needed	Why
Medical record	20+ years	Patient privacy law, HIPAA
Bank transaction / Intellectual Property	7-10 years	Financial regulations, competitive advantage
Factory sensor telemetry (temperature)	1-2 years	Short-lived operational data
Government classified secret	25+ years	National security purposes

Why cover time matters with the quantum AND the "harvest now, decrypt later" concept:

1. **Today (2026):** You send data encrypted with your old RSA/ECC lock. An attacker does NOT need a quantum computer yet. They just **record and store your encrypted traffic** - like photocopying a locked safe and keeping the copy [2][5].
2. **2030 (predicted CRQC):** Cryptographically relevant quantum computer (CRQC) arrives that can pick old RSA/ECC locks [3]. An attacker now **opens the stored copy and reads your old data** [2].
3. **Result:** Data that should have stayed secret until 2046 if quantum is not available, is exposed in 2030 if quantum becomes widely available for use.

Concrete timeline example:

```
2026: You send medical record (needs secrecy until 2046 = 20-year cover time)
      |
      +--> Attacker records encrypted packet in 2026 (by harvesting for data)
      |
2030: Quantum computer arrives (CRQC) [3]
      |
      +--> Attacker decrypts 2026 packet in 2030
      |
      = Data exposed 16 YEARS too early (should be secret until 2046, but exposed in 2030)
```

Even though quantum is theoretically 4 years away (2026→2030), your 20-year data is already at risk today because an attacker can harvest your data now [3].

Rule of thumb:

- If (cover duration + migration duration) > (duration until quantum computer arrives), you are already late.`
- **Migration itself takes 10-20 years for organizations with alot of large sensor devices** [3]
- CRQC is theoretically predicted by the EU to become available by 2030, which is 4 years away [3]
- Example: Medical data cover time 20 years + migration 10 years = 30 years needed. Time until quantum 4 years. 30 years > 4 years → so we are already late, and must start by preparing an inventory of devices using crytography now [5]
- Short-lived telemetry cover time 1-2 years + migration 10 years = 11~12 years > 4 years → So sensor telemetry data could still be at risk, but lower priority/sensitivity than in the medical domain.

How we used cover time in our system:

- Our temperature telemetry maybe needs 1 to 2 years of cover time as it is short-lived data, so ML-KEM-512 (~AES-128) is probably enough [1]
- If a system collected health data needing 20 years of cover time, we would use ML-KEM-768 (recommended default) or 1024 (NSA CNSA 2.0 for national security) for longer cover time [1][2]

Our Group Project

Our group's system (in the GitHub repo) is a minimal but working example of the hybrid deployment approach: legacy sensors retain the lightweight AES encryption method when communicating with the edge gateway, and the edge gateway communicates with the cloud service protected by Post-Quantum Cryptography, with a SQLite database for analytics and fallback logging via files for business continuity. It shows how an organization can start now and migrate to using Post-Quantum Cryptography without disrupting operations.

---

2. Why Legacy Matters: 2KB RAM Cannot Do PQC (Post-Quantum Cryptography)

Our baseline sensor device simulates **ATmega328P** (Arduino Uno): 16 MHz, 32KB Flash, **2KB SRAM** working memory. It sends telemetry JSON ~95B, encrypted via AES-128-GCM with 16B pre-shared key `legacy_secret_16`, 12B random nonce prepended, wire packet ~123B, overhead 28B (12 nonce + 16 tag), 0B HTTP overhead via raw TCP + EOF framing [4].

ML-KEM-512 needs **secret key 1632B** plus **1000-1500B workspace** for polynomial operations = ~3KB total, exceeding 2KB SRAM → stack overflow and crash [4]. This is not unique to our simulation - many real-world low-cost IoT devices (LoRaWAN, Zigbee, BLE) have similar constraints and cannot be upgraded to Post-Quantum Cryptography without hardware replacement [4]. Post-Quantum Cryptography also introduces larger key sizes and increased processing power compared to classical cryptography, and existing protocols assume specific key sizes that Post-Quantum Cryptography exceeds, requiring protocol modifications [4].

Implication for organization: You cannot push a firmware update to make old sensors quantum-safe. EU roadmap shares that hybrid-PQC ciphers/certificates are needed for legacy compatibility and hardware replacement may be required [3]. Forcing PQC onto 2KB devices would exhaust RAM and battery. Many legacy low-cost IoT devices may not support Post-Quantum Cryptography at all,

necessitating hardware replacements in some cases [3].

Our solution (offload pattern): Keep Link1 unchanged between legacy sensor device and the edge gateway (no firmware update). Let **edge gateway (Linux/Raspberry Pi)** act as the secure intermediary - it has enough RAM, decrypts AES-GCM, validates schema of the data received from the sensor, checks that the sensor data was not part of a replay attack, then re-encrypts for sending to the cloud service via Post-Quantum Cryptography [4]. This pattern is recommended for resource-constrained devices [4]. Gateway measured encapsulation time of approximately ~0.03ms using Rust or 0.82ms using pure Python; decapsulation time of approximately ~0.04ms using Rust or 1.46ms using pure Python, which is negligible for edge gateway, but heavy for sensor supported by batteries.

---

3. Organization Migration Approach

CISA's Post-Quantum Cryptography initiative shares a phased, risk-based migration, not a sudden replacement [5]:

1. **Inventory:** List all systems performing cryptography - including hidden IoT sensors, gateways, cloud APIs. Most organizations discover 60-80% more cryptography use than expected (inventory challenge). **Include non-production systems: internal APIs, test/dev platforms are often overlooked and frequently targeted precisely because they lag behind in security** [3]. EU emphasizes first mapping and creating an inventory of cryptographic systems [3]. **CISA recommends Automated Cryptographic Discovery and Inventory (ACDI) Tools to automate process of getting a first draft of your inventory and on an ongoing basis if possible** [5]. Maintaining a detailed cryptographic asset register/inventory is important to assess the risk of each system or API endpoint [3].
2. **Risk assessment using cover time:** Identify data with long secrecy lifetime at risk from "harvest now, decrypt later" [5]. **Use cover time to prioritize:**
    - List each data type + its cover time (medical 20 years, financial 7-10 years, IP 10 years, telemetry 1-2 years)
    - If cover time extends beyond 2030 (predicted CRQC), that data is already at risk from traffic captured today [2][3]
    - **Example:** Medical record sent in 2026 needs secrecy until 2046 (20 years cover time). If an attacker records encrypted traffic in 2026, decrypts in 2030 with quantum, they can read data 16 years before it should be public. So prioritize long 'cover time' data first [3]. This is why EU says if cover time is more than 5 years, it may already be too late [3].
3. **Approach:** Prioritize internet-facing communication links first (e.g. gateway to cloud communication links), then internal communication links. EU recommends a hybrid approach to keep legacy sensor devices working during the transition [3]. **TLS 1.3 should be the first step to implement as it provides necessary foundation for future Post-Quantum Cryptography support** [3].
4. **Hybrid migration:** Deploy Post-Quantum Cryptography alongside traditional cryptography, with a fallback for backward compatibility. If Post-Quantum Cryptography fails, fallback avoids bringing the whole system down, which is very important for business continuity [5]. Both EU and NIST advise **hybrid-PQC ciphers and hybrid digital certificates** - a hybrid approach provides security of the new Post-Quantum Cryptography technique while allowing legacy devices that do not support Post-Quantum Cryptography to continue using classical cryptography [3]. This requires both ends (browser/server, IoT device/cloud) to support the same cryptography algorithms [3].
5. **Supply chain:** Work with vendors to ensure new sensor devices are PQC-capable. CISA product categories list (Jan 2026) now prioritizes PQC-capable products in procurement [5]. CISA develops and regularly updates this list [5].

EU roadmap adds: expect 10-20 years for a full migration in large organizations, and they need vendor cooperation, and need to plan for constrained radio overhead (used in low power sensors such as in agriculture or environment/climate monitoring) [3]. The web has seen some progress: hybrid-PQC ciphers are already adopted in 8.6% of world's top 1 million websites, but hybrid-PQC certificates are still in the early stages of implementation. [3] This shows that migration to post-quantum cryptography is feasible and already started.

Cost: Replacing 10,000 sensors at €50 each = €500k + installation + downtime. Hybrid offload lets you keep old sensors running while new PQC-capable devices (e.g., ESP32 with >8KB SRAM) are phased in. An estimate by the US government in 2024, shared that it might take USD 7.1 billion to migrate prioritised federal civilian systems to Post-Quantum Cryptography between 2025 and 2035. [7]

---

4. Our Phased Strategy as an Organization Example

We implemented a hybrid strategy which CISA/EU recommend, to show that the hybrid strategy is feasible:

Phase 1 - Legacy Only (Baseline, 27/33 tests passed):

- Link1: Legacy → Gateway AES-128-GCM PSK, TCP 5000, EOF
- Link2: No Post-Quantum Cryptography. Plaintext only
- Risk: "harvest now, decrypt later" is possible on internet-facing edge gateway and cloud service communications, if the communications is via the public internet [5]

Phase 2 - Hybrid Approach (Current Build, 33/33 tests passed):

- **Link1 Between Legacy Sensor Device to Edge Gateway unchanged:** Legacy devices keep same PSK/Pre-Shared Key. This preserves our legacy sensor devices and keeps them working until they are ready to migrate to Post-Quantum Cryptography.
- **Edge Gateway:** After validating telemetry data received from sensor device, gateway loads the public key `cloud_public_key.bin` 800B [2] and encapsulates the data. Wire format `ct(768)||nonce(12)||aes_ct` ~845B total [2]. This is the hybrid pattern: KEM establishes a 32B shared secret `ss` without transmitting it directly, then AES-256-GCM encrypts actual data [2].
- **Why ML-KEM-512:** Lowest overhead 800B pk + 768B ct = 1568B vs 2272B for 768 (1184+1088) vs 3136B for 1024 (1568+1568) [2]. Offers around 128-bit security, sufficient for short-lived telemetry (with a life of minutes/hours). 2026 recommendation is ML-KEM-768 as the default - which balances strong security and reasonable sizes, TLS hybrid group X25519MLKEM768 uses it [2]. Choose ML-KEM-1024 if you need longer-term margin or must follow NSA CNSA 2.0, which requires 1024 for national security systems [2]. If long-term confidentiality is needed (e.g. in the medical domain), we should use ML-KEM-768 [1]. We chose ML-KEM-512 for our minimal viable gateway (Linux/Raspberry Pi) - encapsulation time of 0.03ms in Rust or 0.82ms in pure Python; decapsulation time of 0.04ms / 1.46ms [2]. The choice of ML-KEM depends on cover time: short cover time (telemetry 1-2y) means 512 bit is enough, long cover time (medical 20 years) requires 768 or 1024 bit [1] [2].
- **Cloud Service:** Decapsulates the data `ss = ML-KEM.decaps(dk, ct)`, AES-GCM decrypts, inserts data into SQLite database `telemetry.db`. Analytics is performed on the SQLite database via health checks and querying for aggregated metrics. E.g. health checks over port 6001: `db_rows`, `COUNT`, `AVG(temperature/humidity)`, `last 10`, `decaps_ok/fail`, `success_rate`, `avg_decaps_ms` [2].
- **Fallback ensures availability:** If the public key is missing or the cloud service is unreachable (e.g. TCP 6000 refused/timeout), the edge gateway will log sensor data and metrics to the `gateway_fallback.log`. This offers business continuity following CISA's hybrid approach guidelines [5]. The IT team can use the logs to do a replay later - so there is no data loss.
- **Operational suitability:** CI-CD via GitHub actions, and managing libraries via `uv`, Dockerfile for reproducible environments taking into account our library dependencies from `uv`.

Phase 3 - Future PQC-Capable Devices:

- New devices with >8KB SRAM (ESP32, Raspberry Pi Pico) could run ML-KEM-512 directly
- Edge Gateway supports both old PSK/Pre-Shared Key and new PQC/Post-Quantum Cryptography devices
- File-based pk/public key will be replaced by KMS(Key Management Service)/certificate, add TLS 1.3 with PQC certs [3]
- Requires sensor device hardware replacements [3][5]

---

5. Risks & Conclusion: Start Preparing Your Inventory Now

Compliance Requirements: CISA's product categories list (Jan 2026) prioritizes PQC-capable product. So procurement should require ML-KEM support for sensor devices [5]. EU's roadmap requires organizations to prepare an inventory of all systems performing cryptography [3] It is important to note that EU's roadmap is more than just advice. EU's guidance might be enforced through directives/regulations. Post-Quantum Cryptography is not explicitly required in GDPR, EU's Cyber Resilience Act (2024) takes a risk-based approach requiring up-to-date policies and industry best practices [3] [6]. NIST guidance is more explicit about protocols but does not enforce it [3].

Enforcement timeline: Both EU and NIST recommend non-PQC encryption to be removed by 2030 for critical systems, and from all other systems by 2035 [3]. With CRQC predicted by 2030 by many, organizations with 5+ years of cover time are already late [3]. Hybrid-PQC ciphers are already implemented in 8.6% of the top 1 million of global websites [3]So the migration to Post-Quantum Cryptography has already started, and is feasible now.

Cost & Timeline: A full migration of around 10 to 20 years might be needed for organizations with alot of sensor devices, where the timeline might be long also because sensors might be found across numerous faraway locations [3][5]. Start preparing a system inventory now, then adopt a hybrid approach (like our Phase 2 approach above) to protect internet-facing communications links without disrupting legacy devices. Then plan for a sensor hardware refresh to PQC-capable devices.

Key Actions (use cover time to prioritize):

1. **Inventory** of all cryptography-performing systems now (including hidden IoT/sensior devices, non-prod internal APIs, test/dev) - Organizations likely have 60-80% more devices/systems than they think [3]. Use automated discovery tools like CISA ACDI [5]. For each system, record "cover time" (how many years must data stay secret).

2. **Prioritize by cover time:** Data with 20y cover time (medical) first, then 7-10y (financial/IP), then 1-2y (telemetry). If cover time + migration time (10-20y) > time until quantum (2030 = 4y away), you are already late [3][5].
3. **Adopt a hybrid migration approach** with fallback - This keeps legacy sensor devices running, while add Post-Quantum Cryptography on internet-facing communication links, to ensure business continuity [5]
4. **Measure PQC observability metrics**: For example, track PQC encapsulation/decapsulation times (in millisecond), success rate, fallback rate, via health checks and analytics on the database collecting your sensor data and metrics.
5. **Plan key management upgrades** (e.g. implement per-device subkeys, sign primary key/pk file, key management system/KMS, key rotation) **and hardware replacement budget**

As part of group 23, the system we created demonstrates that even a small team with LLM assistance can build a working hybrid Post-Quantum Cryptography system, with tests passing, and metrics on the sensor data and health checks, with fallback to ensure backward compatibility with legacy sensor devices availability. So this project proves that the organization transition to Post-Quantum Cryptography is feasible if organizations started now.

Cover time concept shows why waiting is risky. The data you send today with 20 years of "cover time" might be exposed 16 years early if you wait until quantum arrives before you start migrating over from classical cryptography to Post-Quantum Cryptography.

References

- [1] NIST FIPS 203 ML-KEM standardised in August 2024 - https://www.encryptionconsulting.com/education-center/ml-kem-fips-203/
- [2] ML-KEM sizes: 800B pk (public key / encapsulation key), 768B ct (ciphertext) - https://vucense.com/privacy-sovereignty/post-quantum-cryptography/ml-kem-fips-203-implementation-guide-2026/
- [3] EU roadmap, hybrid for legacy, hardware replacement may be needed - https://www.helpnetsecurity.com/2025/07/10/david-warburton-f5-labs-eu-pqc-roadmap/
- [4] Legacy constraints, computational overhead - https://eureka.patsnap.com/report-how-to-adapt-post-quantum-standards-to-existing-legacy-systems
- [5] CISA PQC initiative, phased migration - https://www.cisa.gov/topics/risk-management/quantum
- [6] EU Cyber Resilience Act - https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act
- [7] 2024 US Government Cost Estimate to Migrate to Post-Quantum Cryptography (Added on 2026.10,19 to address a peer review feedback to get the cost estimate) - https://bidenwhitehouse.archives.gov/wp-content/uploads/2024/07/REF_PQC-Report_FINAL_Send.pdf